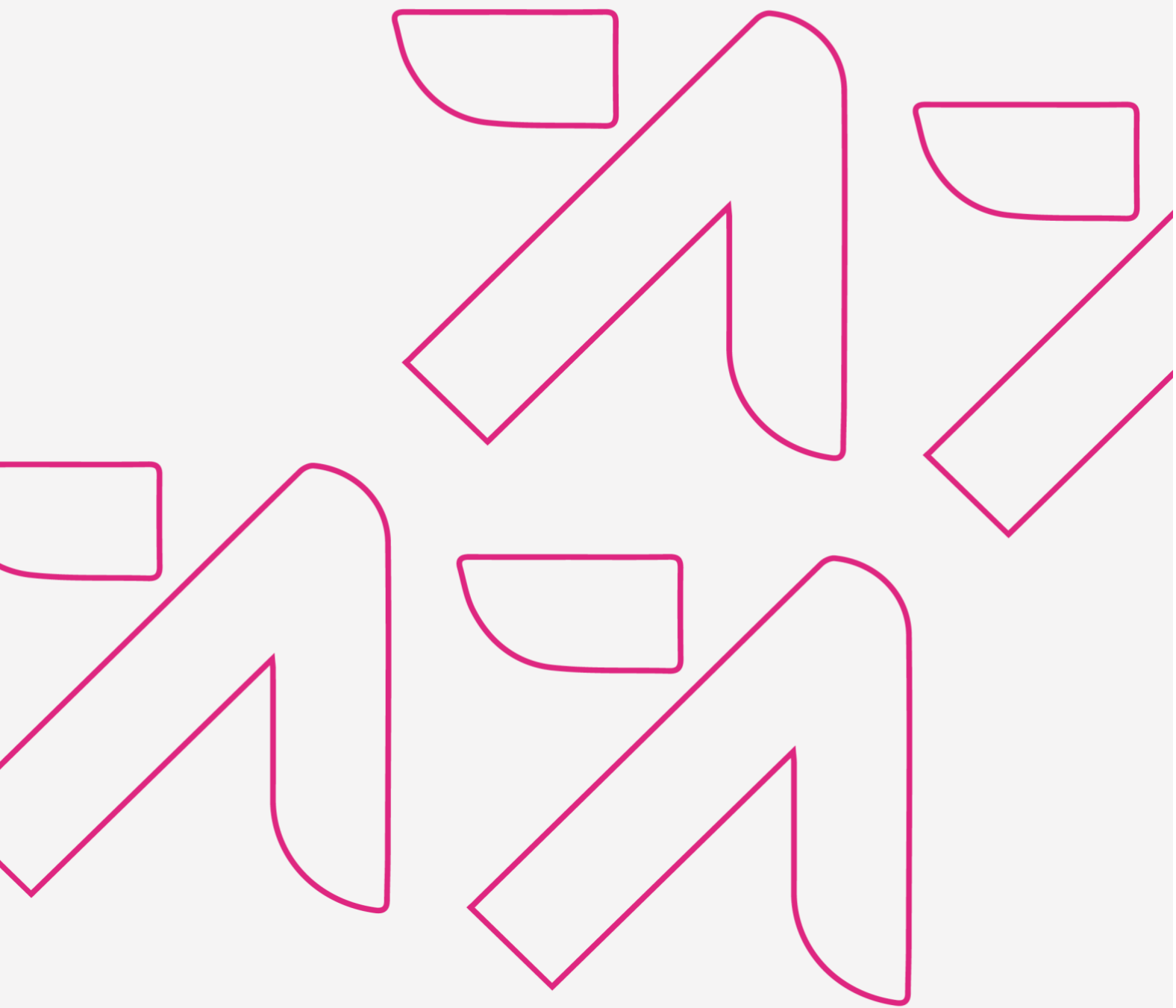




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT8. Monitorización, registros y auditoría continua

Encaje en el curso 2026/2027: esta unidad desarrolla el análisis de logs del RA5 (tema 10) y la detección en el equipo del RA7 (tema 13, HIDS). Wazuh, que usamos en clase, cubre casi todo lo que aparece aquí.

1. Objetivo de la monitorización y la auditoría

La monitorización y la auditoría garantizan que la organización pueda detectar actividad anómala, evidencias de ataques y fallos de configuración en tiempo real o casi real. Sin registros, la seguridad es ciega. Sin auditoría continua, los incidentes se descubren tarde o jamás.

El objetivo central es tener **visibilidad, alertas útiles y trazabilidad completa** de todo evento relevante.

2. Tipos de registros (logs) esenciales

2.1. Logs del sistema operativo

- Inicios y cierres de sesión
- Elevaciones de privilegios
- Cambios en cuentas de usuario
- Fallos del sistema
- Modificaciones de archivos clave

Linux: journald, syslog, auditd

Windows: registros de eventos de Windows (Seguridad, Sistema, Aplicación), ampliados con Sysmon para ver procesos, conexiones de red y cambios en el registro.

Eventos de Windows que conviene saberse

ID	Qué indica
4624 / 4625	Inicio de sesión correcto / fallido
4672	Inicio de sesión con privilegios especiales
4688	Creación de un proceso
4720 / 4732	Cuenta creada / usuario añadido a un grupo local
4740	Cuenta bloqueada
1102	Se ha borrado el registro de seguridad

2.2. Logs de red

- Firewall: tráfico permitido/denegado
- IDS/IPS: detecciones de firmas o anomalías

- Registros de proxies o gateways
- Logs de VPN

2.3. Logs de aplicaciones

- Servidores web
- Bases de datos
- APIs
- Aplicaciones corporativas
- Mensajería: SMTP, IMAP, etc.

2.4. Logs de seguridad

- Alertas de EDR/antimalware
- Intentos de acceso fallidos
- Actividad sospechosa
- Cambios de políticas de seguridad

3. Centralización de logs

3.1. Por qué centralizar

- Evita manipulación local
- Facilita correlación entre sistemas
- Permite análisis histórico
- Simplifica auditorías

3.2. Herramientas comunes

- Wazuh
- Elastic Stack (Elasticsearch + Kibana) u OpenSearch
- Graylog
- Splunk (cuando hay presupuesto)
- SIEMs comerciales

3.3. Requisitos

- Envío cifrado
- Retención según política
- Acceso solo para personal autorizado
- Integridad garantizada (hashes, firmas, controles)
- Hora sincronizada por NTP en todos los equipos: sin relojes coherentes no se puede correlacionar nada

4. Indicadores clave y eventos relevantes

4.1. Autenticación

- Logins fallidos repetidos
- Logins fuera de horario
- Logins desde IPs inusuales
- Accesos administrativos sin justificar

4.2. Cambios de configuración

- Modificación de reglas de firewall
- Alteración de permisos
- Cambios en políticas de seguridad
- Nuevos servicios escuchando en puertos

4.3. Movimiento lateral

- Conexiones internas inesperadas
- Uso de herramientas administrativas no habituales (psexec, wmiexec, ssh inusual)

4.4. Comportamientos anómalos

- Aumento de tráfico
- Ejecución de binarios desconocidos
- Consumo anómalo de CPU/Memoria
- Descargas automatizadas anormales

5. Auditoría continua

5.1. Concepto

Proceso en el que los sistemas se evalúan periódicamente para asegurar cumplimiento de políticas, detectar configuraciones incorrectas y anticipar fallos de seguridad.

5.2. Alcances típicos

- Revisión de permisos y roles
- Configuraciones del sistema operativo
- Parámetros de seguridad (SSH, RDP, firewall)
- Versiones y parches
- Exposición de servicios

5.3. Herramientas

- Lynis (**Linux**)
- **Windows** Security Baselines

- OpenSCAP
- Wazuh con módulos de auditoría
- CIS-CAT (para benchmarks CIS)

6. Detección basada en comportamiento

No se trata solo de firmas. Los ataques modernos requieren análisis de comportamiento:

6.1. Técnicas

- Detección de anomalías estadística
- Correlación de eventos
- Machine learning aplicado a logs (en plataformas avanzadas)
- Análisis de comportamiento de usuarios y entidades (UEBA)

6.2. Beneficios

- Detecta ataques sin firma
- Captura movimientos laterales difíciles de identificar
- Identifica actividad interna maliciosa

7. Gestión de alertas

7.1. Evitar el ruido

Demasiadas alertas generan fatiga de seguridad. Hay que configurar alertas **realmente relevantes**.

7.2. Prioridades

- Alta: actividad maliciosa o acceso no autorizado
- Media: cambios de configuración sensibles
- Baja: eventos informativos o de diagnóstico

7.3. Buenas prácticas

- Definir quién recibe cada tipo de alerta
- Trazabilidad para ver qué se hizo tras la alerta
- Playbooks de respuesta

8. Correlación de eventos y SIEM

8.1. Qué hace un SIEM

Recopila, correlaciona y analiza logs para identificar ataques complejos que no se verían mirando un solo sistema.

8.2. Casos que detecta

- Ataques distribuidos
- Uso simultáneo de credenciales en varios sistemas
- Secuencias de pasos típicas de intrusiones
- Privilege escalation + acceso anómalo + exfiltración

8.3. Buenas prácticas

- Ingesta solo de logs útiles
- Reglas personalizadas
- Dashboards enfocados en riesgos reales
- Revisión frecuente de reglas obsoletas
- Mapear las reglas a **MITRE ATT&CK** para saber qué técnicas se detectan y cuáles no
- Aprovechar reglas de la comunidad en formato **Sigma**, que se convierten al lenguaje de cada SIEM

9. Retención y cumplimiento

9.1. Períodos comunes

- 90 días para análisis operativo
- 1 a 2 años para cumplimiento (dependiendo del sector)
- 5 años en sectores regulados (finanzas, legal)

Son cifras orientativas: el plazo real lo marcan la normativa del sector y la categoría del sistema (por ejemplo, el ENS en el sector público). Y como los logs contienen datos personales (usuarios, direcciones IP), el RGPD obliga a no guardarlos más tiempo del necesario y a controlar quién los consulta.

9.2. Integridad

- Firmas digitales
- Hashes
- Almacenamiento WORM (Write Once Read Many) en entornos críticos

10. Buenas prácticas finales

- Centralizar TODO, siempre.
- No depender de logs locales.
- Habilitar auditoría avanzada en **Windows** y **Linux**.
- Documentar qué debe generar logs y por qué.
- Revisiones semanales de eventos críticos.

- Alertas ajustadas para evitar ruido.
- Correlación entre sistemas, no análisis aislado.
- Integración con IR (respuesta a incidentes).
- Copias inmutables de logs críticos.
- Zero Trust aplicado también a monitorización: no se confía en lo que no está registrado.

Para ampliar

- Documentación de Wazuh: recogida de logs, reglas, SCA y FIM.
- MITRE ATT&CK y el repositorio de reglas Sigma.
- Guía CCN-STIC 831: registro de la actividad de los usuarios (ENS).
- NIST SP 800-92: gestión de registros de seguridad.